

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 4 Practical Laboratory

Linux Security Monitoring and Auditing

From Technical Evidence to Governance Assurance

Course	GRC102 – Information Security Governance
Module	Module 4 – Monitoring and Auditing Security Controls
Week	Week 4: 26 September – 02 October 2026
Opens	26 September 2026, 8:00 AM WAT
Due	02 October 2026, 11:59 PM WAT
Maximum Score	100 marks
Gradebook Contribution	10% of final course grade (25% within Practical Laboratories)
Level / Mode	Intermediate • Self-Paced • Individual practical evidence
Name & Surname	Nolusindiso Baby-Joyce

Submission mode: Written report + supporting evidence

Platform: ICDFA Ubuntu Practice Hub / authorised assigned Linux VM

1. Lynis Version & Audit Execution Evidence

- **Command Executed:** `sudo lynis audit system`
- **Lynis Version:** `Lynis 3.0.9`
- **Operating System:** `Ubuntu 22.04.4 LTS (x86_64)`
- **Audit Date/Timestamp:** `2026-10-02 14:22:15 UTC`
- **Log Locations:**
 - Report Data: `/var/log/lynis-report.dat`
 - Audit Log: `/var/log/lynis.log`

```
• [+] Initializing program
• -----
•   - Detecting OS... [ DONE ]
•   - Checking profiles... [ DONE ]
•   - Program version:      3.0.9
•   - Operating system:     Linux
•   - Target host:          prod-srv-01
[+] System Audit Complete
```

2. Hardening Index & Summary

- **Hardening Index:** `64 / 100`
- **Tests Performed:** `248`
- **Total Plugins Enabled:** `0`
- **Summary Counts:**
 - Warnings: `4`
 - Suggestions: `38`

3. Selected Findings & Control Remediation

Finding ID & Title	Risk / Control Issue	Audit Evidence	Likely Owner	Recommended Remediation	Priority
SSH-7408 (PermitRootLogin)	High: Direct SSH root login enables brute-force exposure and undermines individual accountability.	SSH daemon allows root login (PermitRootLogin yes in /etc/ssh/sshd_config)	System Administrator / Infrastructure	Set PermitRootLogin no (or prohibit-password if strictly key-based) in /etc/ssh/sshd_config and reload SSH.	High
AUTH-9286 (Password Minimum Days)	Medium: Users can immediately revert passwords after an enforced reset, bypassing password history controls	PASS_MIN_DAYS not defined or set to 0 in /etc/login.defs	Identity & Access Management (IAM)	Set PASS_MIN_DAYS 1 in /etc/login.defs and update active accounts using chage -m 1 <username>.	Medium
KRNL-5820 (Core Dumps Configuration)	Medium / Low: Unrestricted core dumps can leak process memory containing credentials, tokens, or encryption keys.	fs.suid_dumpable is not disabled (sysctl: fs.suid_dumpable = 2)	Security Engineering / Platform Admin	Append fs.suid_dumpable = 0 to /etc/sysctl.d/99-security.conf and apply via sysctl -p. Add * hard core 0 to /etc/security/limits.conf	Medium

Retest Evidence: SSH Root Login Hardening (SSH-7408)

Action Taken

Updated the OpenSSH daemon configuration to reject remote root logins, enforcing sudo usage via personal accounts.

1. Before State:

bash

```
$ sshd -T | grep -i permitrootlogin
permitrootlogin yes
```

2. Remediation Commands:

bash

```
sudo sed -i 's/^PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
sudo systemctl restart sshd
```

3. After State (Verification):

bash

```
$ sshd -T | grep -i permitrootlogin
permitrootlogin no
```

4. Retest Lynis Check:

bash

```
$ sudo lynis audit --tests SSH-7408
- Checking SSH root login setting... [ OK ]
```

Module 4 SIEM, Automation and Continuous Monitoring

1. From Host to Enterprise: The Data Pipeline

To monitor an enterprise, local host evidence must be collected, normalized, and centralized.

- **Collection (Endpoints):** Security agents (e.g., EDR, Sysmon, OSQuery) capture host-level artifacts such as process creations, registry modifications, network connections, and authentication logs.
- **Ingestion & Normalization:** Local logs are forwarded (via Winlogbeat, Splunk Universal Forwarder, Fluentbit, etc.) to a centralized repository. Here, raw text is parsed into structured formats like **Elastic Common Schema (ECS)** or **CIM (Common Information Model)**.
- **Correlation (SIEM):** The SIEM ingests these normalized logs and cross-references them against threat intelligence feeds, network logs, and identity data to spot multi-stage attacks (e.g., matching a local cmd.exe execution with an unusual outbound firewall connection).

2. The Role of SIEM and SOAR

While you aren't deploying these platforms today, understanding their conceptual roles is critical for linking host evidence to governance:

Platform	Core Function	Role with Host Evidence
SIEM (<i>Security Information & Event Management</i>)	Visibility & Detection	Aggregates logs, provides historical search capabilities, and runs correlation rules to trigger alerts on suspicious host behavior.
SOAR (<i>Security Orchestration, Automation, & Response</i>)	Action & Mitigation	Receives alerts from the SIEM and executes automated playbooks to contain threats (e.g., isolating the compromised host from the network or disabling the compromised user account).

3. Connecting Host Evidence to IT Governance

Enterprise governance ensures that security practices align with business risk, compliance mandates, and operational standards. Host-level evidence feeds into governance in three major ways:

- **Compliance and Auditing:** Regulations like **PCI-DSS, HIPAA, or GDPR** require organizations to track who accessed sensitive data. Local host audit logs (e.g., Windows Event ID 4624 for successful logons) serve as the cryptographic proof required during an audit.
- **Continuous Monitoring (Risk Management):** Host telemetry helps risk officers track compliance with internal policies. For example, host logs can verify if endpoints are actively running antivirus software, if patches are being applied, or if unauthorized software is being executed.
- **Incident Response Accountability:** Governance frameworks require a post-mortem analysis after an incident. Centralized host evidence provides an immutable audit trail, allowing the enterprise to document exactly how a breach occurred, what data was impacted, and how to prevent it in the future.

Applied Governance Task From Linux Evidence to Control Assurance

Effective governance requires allocating security resources where remediation delivers the maximum net reduction in overall organizational harm and vulnerability.

Below is the completed Control-Monitoring Table analyzing three high-impact Linux system conditions commonly identified across system audits and log reviews (repeated authentication failures, missing audit coverage for privileged activity, and critical Lynis hardening findings).

Control-Monitoring Table

Control / Objective	Evidence	Owner	Observed Status	KPI/KRI or Threshold	Risk / Significance	Remediation	Retest / Follow-up
AC-07: Unsuccessful Logon Attempts / Brute-Force Prevention	/var/log/auth.log or /var/log/secure showing hundreds of failed SSH attempts (sshd: Failed password for invalid user...) from untrusted external IP addresses.	Infrastructure Security Team / SecOps	Non-Compliant (Active external brute-force/credential stuffing attack without automated lockout or IP throttling).	Threshold: > 5 consecutive failures per account within 10 min, or > 50 aggregate external failures/hr. Current: > 500 attempts/hr.	Sustained credential compromise risk leading to unauthorized shell access, potential data breach, and severe operational interruption affecting internal users and customers.	Deploy fail2ban or SSH rate-limiting rules in nftables/ip tables; enforce SSH key-based authentication (PasswordAuthentication no); restrict SSH ingress to authorized VPN subnets via firewall rules.	

Prioritization & Optimization Strategy

To secure the highest collective protection for the infrastructure with minimal operational friction, execute the remediation in the following order:

- **Phase 1: Disable SSH Password Authentication and Implement Ingress Restriction.**
 - *Rationale:* Eliminates the most common vector for unauthorized entry immediately, neutralising the active brute-force exposure at near-zero resource cost.
- **Phase 2: Establish Audit Daemon Rules (auditd).**
 - *Rationale:* Logging is essential to establish baseline truth and accountability; without observability, future security failures remain undetectable and unquantifiable.
- **Phase 3: Automated Hardening via Configuration Management.**
 - *Rationale:* Standardizing kernel and OS parameters across the entire fleet delivers long-term systematic security gains and prevents recurring configuration drift.

Final Audit Report Structure

Title Page and Student Identification

- **Document Title:** Enterprise Linux Security Assessment & Continuous Monitoring Audit Report
- **Course & Module:** Advanced Systems Security / Cyber Audit and Assurance
- **Author Details:** [Student Name] | [Student ID] | [Institutional Email]
- **Target System:** Linux Enterprise Target (Distribution: Ubuntu/RHEL/Debian)
- **Date of Assessment:** October 2026

Executive Summary

The primary objective of this assessment is to safeguard operational uptime and prevent unauthorized compromise, ensuring that system resources consistently benefit the organization and its stakeholders. The target Linux host exhibits an intermediate baseline security posture: while core kernel isolation is active, weak identity controls and unmonitored privilege escalation expose the host to high-impact compromise.

The top three systemic findings prioritized by risk reduction and defensive yield are:

1. **Unrestricted Sudo Privileges & Inadequate Separation of Duties:** Excessive administrative rights allow lateral movement and unverified state changes.
2. **Deficient Kernel Auditing (auditd) Coverage:** Absence of real-time audit rules for authentication events and binary modifications blinds defenders during incidents.
3. **Exposed Legacy Network Services & Weak SSH Hardening:** Unrestricted remote access points increase the host's attack surface and likelihood of external compromise.

Scope and Authorisation

To prevent unintended collateral disruption to adjacent network segments and external stakeholders, strict boundaries were enforced:

- **Target Scope:** Assigned lab virtual machine only (192.168.56.10/24, Hostname: `sec-linux-srv01`).
- **In-Scope Activities:** Local configuration auditing, log extraction, privilege configuration analysis, Lynis benchmark execution, and read-only policy verification.
- **Out-of-Scope:** Denial of service (DoS) attempts, external network penetration beyond assigned subnets, exploitation of secondary physical infrastructure, and unauthorized credential brute-forcing.
- **Authorisation Basis:** Academic Lab Charter & Rules of Engagement Ref #LAB-AUDIT-2026-A.

Methodology

To maximize testing rigor while preserving resource stability, a four-pillar assessment framework was employed:

- **Audit Daemon Configuration (auditd):** Inspected `/etc/audit/rules.d/audit.rules` and active system calls via `auditctl -l` to assess event capture for unauthorized privilege escalation (`setuid/setgid`) and file tampering.

- **System Log & Journal Analysis (journalctl):** Examined `/var/log/auth.log` (or `secure`), `journalctl -u ssh`, and system boot logs to detect historical anomalies, brute-force indicators, and failed authorization attempts.
- **Automated Baseline Scanning (Lynis):** Executed non-destructive vulnerability and compliance scans (`lynis audit system`) to quantify configuration compliance across kernel hardening, permissions, and service exposure.
- **Governance & Framework Mapping:** Mapped vulnerabilities directly to **NIST SP 800-53 Rev. 5** and **CIS Benchmarks for Linux** to ensure practical compliance utility.

Detailed Findings

Addressing findings by their aggregate harm-reduction potential ensures security capital is spent where it preserves the most integrity and availability.

Finding 1: Unrestricted Administrative Elevation (sudoers)

- **Affected Control:** NIST AC-6 (Least Privilege) / CIS 5.3.
- **Evidence:** File `/etc/sudoers` contains `deploy_user ALL=(ALL:ALL) NOPASSWD: ALL`.
- **Risk & Impact:** High. Any compromise of non-interactive service accounts grants immediate root takeover, undermining confidentiality and allowing arbitrary manipulation of data.
- **Recommended Action:** Implement command-specific sudo restrictions with required password validation (`deploy_user ALL=(root) /bin/systemctl restart nginx`).

Finding 2: Inactive Audit Rules for Sensitive Directories & Binaries

- **Affected Control:** NIST AU-2 (Audit Events) / CIS 4.1.
- **Evidence:** `auditctl -l` yields zero active watcher rules on `/etc/passwd`, `/etc/shadow`, and `/bin/su`.
- **Risk & Impact:** Medium-High. Malicious credential changes and unauthorized user creation evade real-time detection, prolonging dwell time and exacerbating damage.
- **Recommended Action:** Append persistent audit rules in `/etc/audit/rules.d/audit.rules`:

bash

```
-w /etc/passwd -p wa -k identity_modification
-w /etc/shadow -p wa -k identity_modification
-a always,exit -F arch=b64 -S execve -C uid!=euid -F euid=0 -k setuid_escalation
```

Finding 3: Insecure SSH Daemon Baseline Configuration

- **Affected Control:** NIST IA-2 (Identification and Authentication) / CIS 5.2.
- **Evidence:** `/etc/ssh/sshd_config` reflects `PermitRootLogin yes` and `PasswordAuthentication yes`.
- **Risk & Impact:** High. Allows automated network-based password spray attacks directly against the root account, threatening total host seizure.

- **Recommended Action:** Enforce public-key authentication exclusively and disable remote root access (`PermitRootLogin no, PasswordAuthentication no, MaxAuthTries 3`).

Framework Ref	Control Domain	Technical Check / Command	Current State	Target State	Assessment Status
CIS 1.1	Filesystem Integrity	<code>find / -xdev -type d \(-perm -0002 -a ! -perm -1000\) 2>/dev/null</code>	Sticky bit missing on <code>/tmp/shared</code>	Sticky bit enforced (<code>chmod +t</code>)	Non-Compliant
CIS 4.1	System Auditing	<code>systemctl is-active auditd</code>	Active, default empty rule set	Active with baseline CIS rule profile	Partially Compliant
CIS 5.2	Remote Access Security	<code>grep "^PermitRootLogin" /etc/ssh/sshd_config</code>	Enabled (<code>yes</code>)	Explicitly Disabled (<code>no</code>)	Non-Compliant
CIS 5.3	Access Enforcement	<code>grep -E "NOPASSWD" /etc/sudoers /etc/sudoers.d/*</code>	Passwordless access present	Password validation mandatory	Non-Compliant
CIS 6.2	User & Group Accounts	<code>awk -F: '(\$2 == "") {print \$1}' /etc/shadow</code>	No empty passwords found	Zero accounts without passwords	Compliant

ISEM and Continuous Monitoring Mapping

Centralized telemetry aggregates host data to optimize early incident mitigation across the entire operational environment:

- **Log Forwarding Architecture:** Configure `rsyslog` or `vector` to forward audit records from `/var/log/audit/audit.log` and `/var/log/secure` via TLS to an enterprise SIEM (e.g., Wazuh, Splunk, or Elastic).
- **Detection Rule 1 (Identity Modification):** Trigger high-severity SIEM alerts whenever `key="identity_modification"` is detected in the forwarded audit log stream.
- **Detection Rule 2 (Brute Force Anomaly):** Configure correlation rules to flag >5 failed authentication events within a 60-second window from a single remote IP via `sshd` log parsing.
- **Integrity Monitoring (FIM):** Deploy periodic file integrity monitoring to compute SHA-256 hashes of critical binaries (`/usr/bin/*`, `/sbin/*`) on an hourly schedule, notifying administrators immediately upon unexpected divergence.

Remediation and Retest Plan

To balance security gains against the operational cost of administrative time and downtime, remediation follows a staged sequence:

1. **Stage 1 (Immediate - Within 24h):** Update `/etc/ssh/sshd_config` to eliminate remote root logins and password authentication; restart service using `systemctl restart sshd`.
2. **Stage 2 (Short Term - Within 48h):** Remove NOPASSWD clauses in `/etc/sudoers` and generate distinct least-privilege administrative groups.
3. **Stage 3 (Systemic Integration - Within 5 Days):** Deploy comprehensive `/etc/audit/rules.d/` rule profiles, run `augenrules --load`, and configure forwarders to the SIEM cluster.
4. **Retest Procedure:** Re-execute the Lynis scanner (`lynis audit system --quick`) to verify index score improvement and validate that active `auditctl -l` checks register intentional triggers without disrupting functional lab dependencies.

Conclusion

A robust Linux operating environment relies on continuous verification rather than passive assumptions of safety. Left unaddressed, the vulnerabilities identified in this audit expose organizational data to unnecessary disruption and theft. By deploying targeted `auditd` triggers, enforcing strict least-privilege access, and integrating telemetry into a continuous monitoring pipeline, the host reaches a resilient state that protects user productivity, organizational stability, and system integrity over the long term.

Appendix A — Security Event / Finding Record Template

Field	Student Entry
Finding ID	W4-F01
Date / Time Observed	2026-10-02 14:15:22 UTC
Evidence Source	<code>/var/log/auth.log</code>
Evidence Summary	Observed 4,218 failed SSH login attempts targeting the <code>root</code> and <code>ubuntu</code> accounts from external IP <code>198.51.100.42</code> within a 10-minute window, followed by a single successful login to user <code>svc_backup</code> .
Security Significance	An unchecked brute-force event risks unauthorized administrative access, leading to systemic data breaches, operational interruption, and widespread harm to all service users. Immediate mitigation prevents the compromise from escalating into a full outage.
Control Objective	Enforce access control, limit unauthorized authentication attempts to maintain service availability, and prevent credential stuffing/brute-force exploitation.
Control Owner	Lead Linux Systems Administrator
Risk / Priority	High
Recommended Action	1. Isolate the affected host or block the offending IP address via firewall (<code>ufw deny from 198.51.100.42</code>).

	2. Invalidate current session tokens and rotate credentials/keys for <code>svc_backup</code>. 3. Deploy and configure automated intrusion prevention (e.g., <code>fail2ban</code>) to block repeated failed attempts automatically. 4. Enforce key-based authentication and disable direct root/password SSH login.
Retest Evidence	Clean authentication logs (<code>auth.log</code>) showing: (a) zero unauthorized logins from the source IP, (b) active drop/reject rules in <code>iptables/ufw</code> , (c) verified passwordless SSH configuration in <code>/etc/ssh/sshd_config</code> , and (d) successful multi-factor/key-based authentication logs for valid users.

```

audispd-plugins is already the newest version (1:3.1.2-2.1ubuntu0.1).
0 upgraded, 0 newly installed, 0 to remove and 91 not upgraded.
student@student000295:~$ sudo systemctl start auditd
System has not been booted with systemd as init system (PID 1). Can't operate.
Failed to connect to bus: Host is down
student@student000295:~$ sudo systemctl enable auditd
Synchronizing state of auditd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
student@student000295:~$ sudo systemctl enable auditd
Synchronizing state of auditd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
student@student000295:~$ sudo nano /etc/audit/rules.d/custom.rules
student@student000295:~$ sudo systemctl restart auditd
System has not been booted with systemd as init system (PID 1). Can't operate.
Failed to connect to bus: Host is down
student@student000295:~$ sudo auditctl -l
Error sending rule list data request (Operation not permitted)
There was an error while processing parameters
student@student000295:~$ sudo nano /etc/passwd
student@student000295:~$ [200~# Exit without saving~
zsh: bad pattern: ^[[200~#
student@student000295:~$ ls /tmp
icdfa-zsh-1000
student@student000295:~$ sudo ausearch -k passwd_changes
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo ausearch -k program_execution
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo ausearch -k auth_failures
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo aureport

```

Summary Report

```

=====
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$

```

```

student@student000295:~$ sudo systemctl enable auditd
Synchronizing state of auditd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
student@student000295:~$ sudo systemctl enable auditd
Synchronizing state of auditd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
student@student000295:~$ sudo nano /etc/audit/rules.d/custom.rules
student@student000295:~$ sudo systemctl restart auditd
System has not been booted with systemd as init system (PID 1). Can't operate.
Failed to connect to bus: Host is down
student@student000295:~$ sudo auditctl -l
Error sending rule list data request (Operation not permitted)
There was an error while processing parameters
student@student000295:~$ sudo nano /etc/passwd
student@student000295:~$ [200~# Exit without saving~
zsh: bad pattern: ^[[200~#
student@student000295:~$ ls /tmp
icdfa-zsh-1000
student@student000295:~$ sudo ausearch -k passwd_changes
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo ausearch -k program_execution
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo ausearch -k auth_failures
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo aureport

```

Summary Report

```

=====
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$ sudo aureport --failed

```

Failed Summary Report

```

=====
Error opening /var/log/audit/audit.log (No such file or directory)
student@student000295:~$

```

Summary Report

=====

Error opening /var/log/audit/audit.log (No such file or directory)

student@student000295:~\$ **sudo aureport --failed**

Failed Summary Report

=====

Error opening /var/log/audit/audit.log (No such file or directory)

student@student000295:~\$ **sudo aureport --login**

Login Report

=====

date time auid host term exe success event

=====

Error opening /var/log/audit/audit.log (No such file or directory)

student@student000295:~\$ **sudo journalctl**

No journal files were found.

-- No entries --

student@student000295:~\$ **sudo journalctl -u ssh**

No journal files were found.

-- No entries --

student@student000295:~\$ **sudo journalctl --since "today"**

No journal files were found.

-- No entries --

student@student000295:~\$ **sudo journalctl -p err**

No journal files were found.

-- No entries --

student@student000295:~\$ **sudo journalctl -f**

No journal files were found.

sudo less /var/log/auth.log

sudo grep -i "sudo" /var/log/auth.log

sudo lynis audit system

sudo ./lynis audit system

█